

VULNERABILITY ASSESSMENT AND SECURITY ANALYSIS

OF A CONTROLLED LAB SYSTEM

COMP404: Computer Security

Practical Assessment Report

NAME: JOSEPH OSEMUDIAMHEN OKOEKOH

INDEX NUMBER: CSC/22/01/0047

LECTURER: DR. GEORGE K. AGORDZO

DEPARTMENT OF COMPUTER SCIENCE

Table of Contents

TABLE OF CONTENTS	2
1. INTRODUCTION	3
1.1 PURPOSE AND OBJECTIVES	3
1.2 SCOPE OF ASSESSMENT	3
2. METHODOLOGY	3
2.1 LABORATORY SETUP AND CONFIGURATION	3
2.2 RECONNAISSANCE AND SCANNING	3
2.3 VULNERABILITY IDENTIFICATION	3
3. LAB SETUP AND SYSTEM DESCRIPTION	4
3.1 VIRTUAL ENVIRONMENT CONFIGURATION	4
3.2 NETWORK CONFIGURATION	4
4. RECONNAISSANCE AND SCANNING FINDINGS	5
4.1 INITIAL NETWORK DISCOVERY	5
4.2 PORT SCANNING RESULTS	5
4.3 SERVICE VERSION DETECTION	6
5. VULNERABILITY IDENTIFICATION AND ANALYSIS	6
5.1 VULNERABILITY #1: VSFTPD 2.3.4 BACKDOOR	6
5.2 VULNERABILITY #2: SAMBA USERMAP SCRIPT	7
5.3 VULNERABILITY #3: UNENCRYPTED TELNET SERVICE	8
6. RISK ANALYSIS AND MITIGATION STRATEGIES	9
6.1 RISK ASSESSMENT MATRIX	9
6.2 MITIGATION RECOMMENDATIONS	9
7. CONCLUSION	10
7.1 ASSESSMENT SUMMARY	10
7.2 KEY FINDINGS	10
7.3 ETHICAL CONSIDERATIONS	10
7.4 FINAL REMARKS	10

1. Introduction

1.1 Purpose and Objectives

This report presents a comprehensive vulnerability assessment conducted on a controlled laboratory environment as part of the COMP404 Computer Security practical assessment. The primary objectives are to identify security vulnerabilities in the Metasploitable 2 target system, analyze associated risks, and propose practical mitigation strategies.

1.2 Scope of Assessment

This assessment is strictly limited to an authorized laboratory environment using VMware Workstation virtualization. The scope includes network scanning, service enumeration, and vulnerability identification on the Metasploitable 2 system. No exploitation activities or data exfiltration were performed.

2. Methodology

This vulnerability assessment follows a structured methodology based on industry-standard penetration testing frameworks. The assessment was divided into distinct phases:

2.1 Laboratory Setup and Configuration

The initial phase involved establishing a secure, isolated testing environment using VMware Workstation. Two virtual machines were deployed: Kali Linux (attacker) and Metasploitable 2 (target). Both systems were configured on a host-only network adapter to ensure complete isolation from production networks.

2.2 Reconnaissance and Scanning

Network discovery was performed using ICMP echo requests to verify host reachability. Comprehensive port scanning was conducted using Nmap to identify all open ports and listening services. Service version detection was performed to determine specific software versions running on open ports.

2.3 Vulnerability Identification

Using the Metasploit Framework, specific vulnerabilities were identified by correlating discovered service versions with known exploits. Each identified vulnerability was thoroughly documented, including its technical details and CVE identifiers where applicable.

3. Lab Setup and System Description

3.1 Virtual Environment Configuration



Figure 1: Kali Linux virtual machine desktop

The penetration testing laboratory was constructed using VMware Workstation as the hypervisor platform. Both virtual machines were configured to use a host-only network adapter, creating an isolated network segment.

3.2 Network Configuration

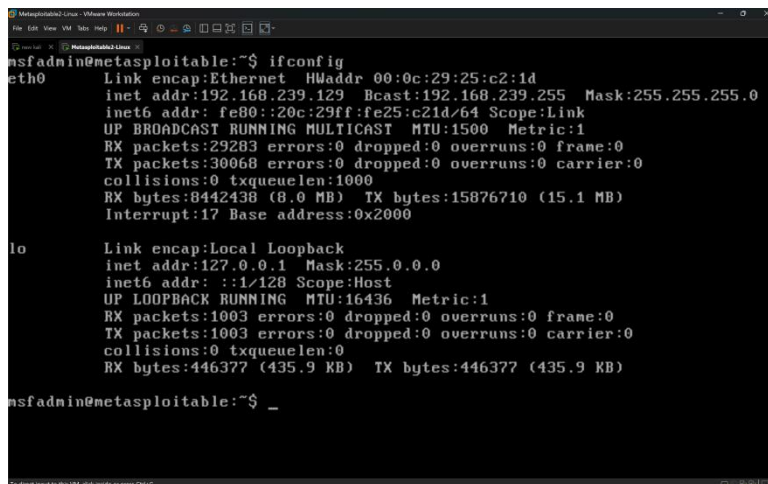


Figure 2: Target system network configuration (IP: 192.168.239.129)

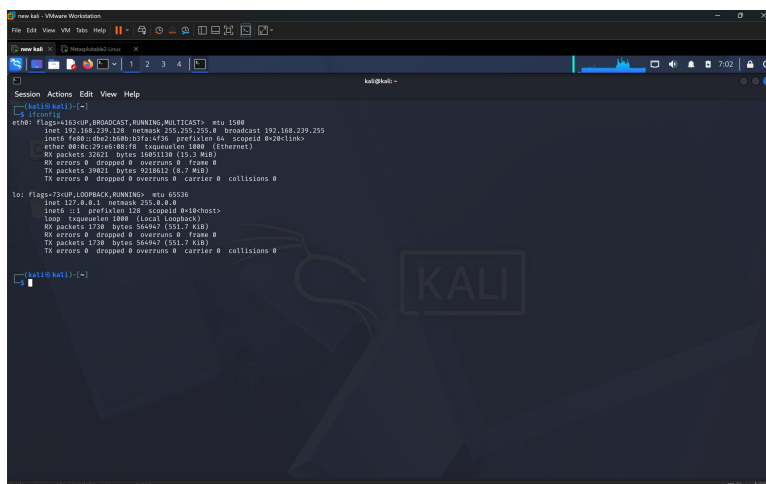
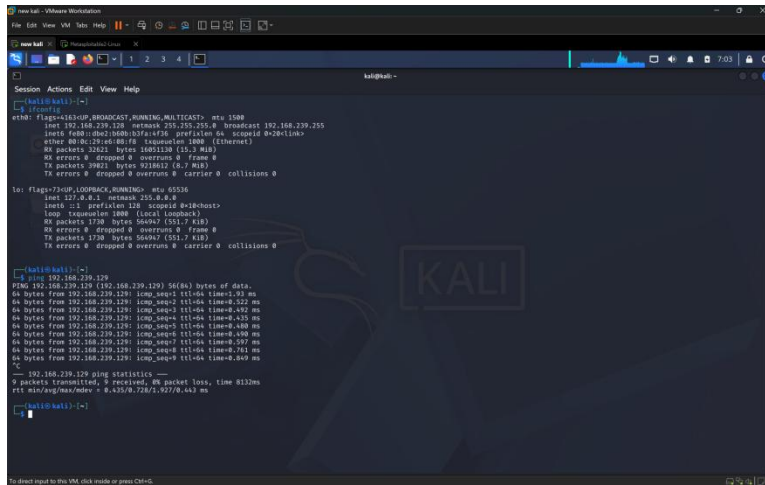


Figure 3: Attacker system network configuration (IP: 192.168.239.128)

4. Reconnaissance and Scanning Findings

4.1 Initial Network Discovery



```

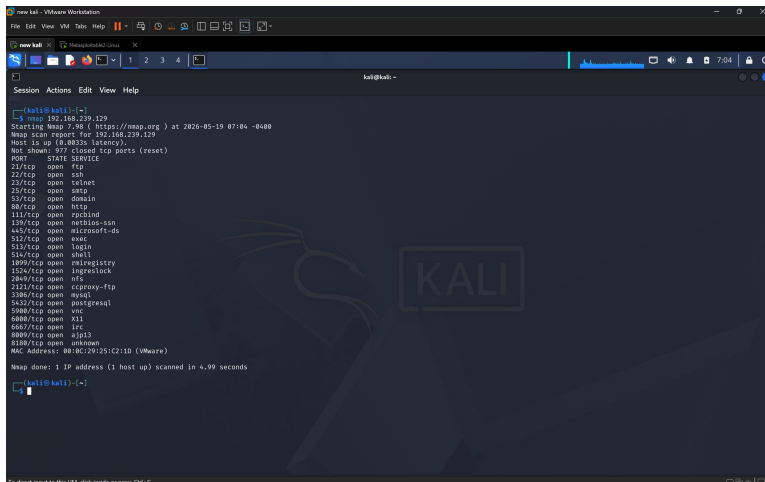
kali@kali:~$ ping 192.168.239.129
PING 192.168.239.129 (192.168.239.129) 56(84) bytes of data:
64 bytes from 192.168.239.129: icmp_seq=1 ttl=64 time=8.93 ms
64 bytes from 192.168.239.129: icmp_seq=2 ttl=64 time=8.52 ms
64 bytes from 192.168.239.129: icmp_seq=3 ttl=64 time=8.492 ms
64 bytes from 192.168.239.129: icmp_seq=4 ttl=64 time=8.53 ms
64 bytes from 192.168.239.129: icmp_seq=5 ttl=64 time=8.488 ms
64 bytes from 192.168.239.129: icmp_seq=6 ttl=64 time=8.588 ms
64 bytes from 192.168.239.129: icmp_seq=7 ttl=64 time=8.587 ms
64 bytes from 192.168.239.129: icmp_seq=8 ttl=64 time=8.56 ms
64 bytes from 192.168.239.129: icmp_seq=9 ttl=64 time=8.469 ms
---
192.168.239.129 ping statistics ---
 9 packets transmitted, 9 received, 0% packet loss, time 812ms
 rtt min/avg/max/mdev = 8.425/8.728/1.927/0.443 ms
kali@kali:~$

```

Figure 4: ICMP ping test confirming target reachability

Basic connectivity testing was performed using ICMP echo requests. The target responded to all ping requests with minimal latency, confirming successful network connectivity and that the host was operational.

4.2 Port Scanning Results



```

kali@kali:~$ nmap 192.168.239.129
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-19 07:04 -0400
Nmap Scan report for 192.168.239.129
Host is up (0.0035s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rcp
135/tcp   open  rshd
139/tcp   open  smb
445/tcp   open  microsoft-ds
512/tcp   open  wsc
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  mirregistry
1247/tcp  open  lmpraise
2049/tcp  open  nfs
3121/tcp  open  cproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6080/tcp  open  x11
6667/tcp  open  irc
8080/tcp  open  http
8188/tcp  open  unknown
NMC address: 8018C795C21D (VMware)
Nmap done: 1 IP address (1 host up) scanned in 4.99 seconds
kali@kali:~$

```

Figure 5: Initial port scan revealing 23 open services

4.3 Service Version Detection

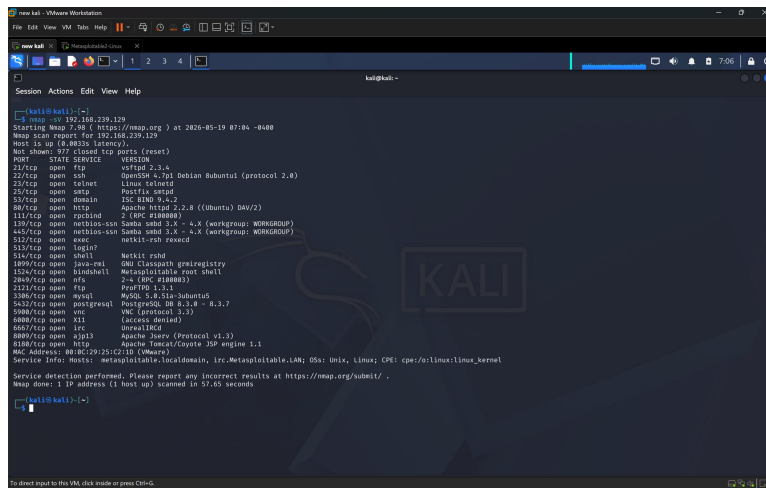


Figure 6: Service version detection identifying vsftpd 2.3.4, Samba 3.X, and other services

The service version detection scan provided critical information about specific software versions. Key findings included vsftpd 2.3.4 on port 21, Samba 3.X on ports 139/445, OpenSSH 4.7p1 on port 22, and Linux telnetd on port 23.

5. Vulnerability Identification and Analysis

5.1 Vulnerability #1: VSFTPD 2.3.4 Backdoor

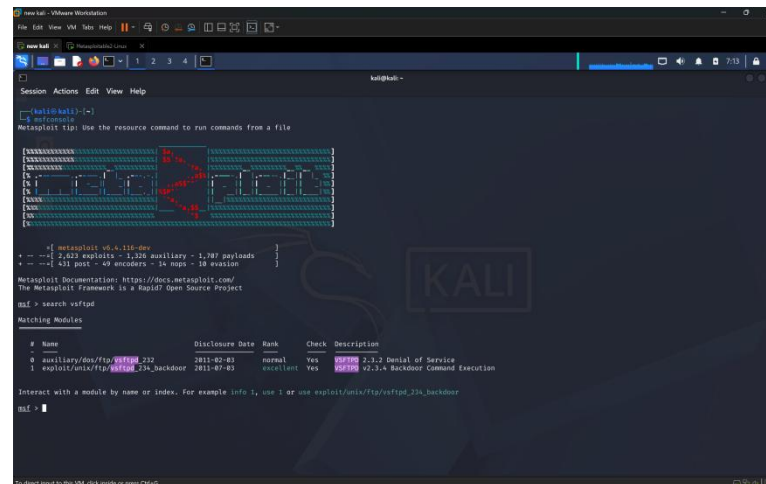


Figure 7: Metasploit search identifying vsftpd backdoor exploit

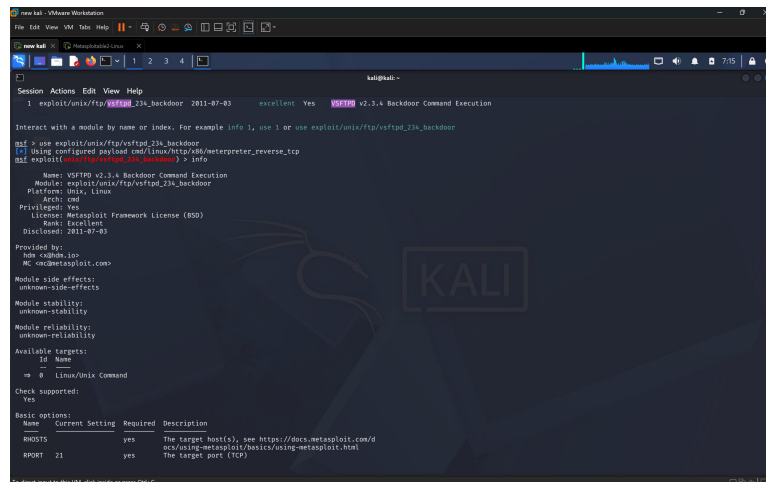


Figure 8: Detailed information about the vsftpd 2.3.4 backdoor (CVE-2011-2523)

The vsftpd 2.3.4 backdoor is a critical remote code execution vulnerability. The malicious code was introduced into the vsftpd source archive in July 2011. When triggered by a specific username containing ':)', the backdoor opens a root shell on port 6200, providing complete system access without authentication.

5.2 Vulnerability #2: Samba Usermap Script

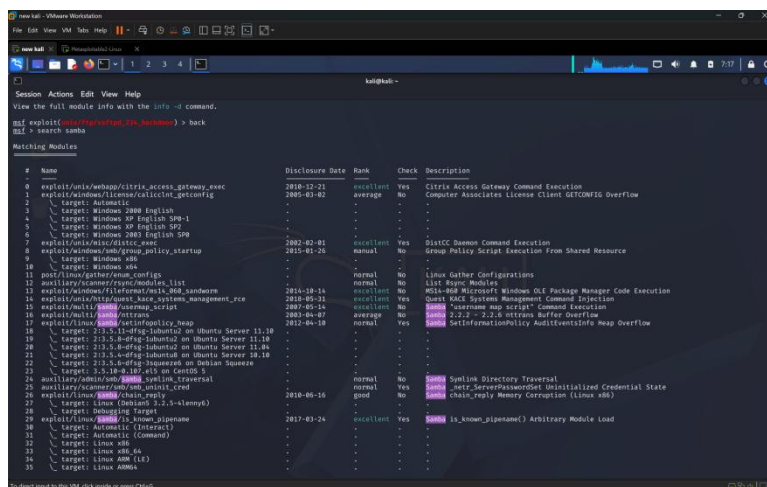


Figure 9: Metasploit search results for Samba vulnerabilities

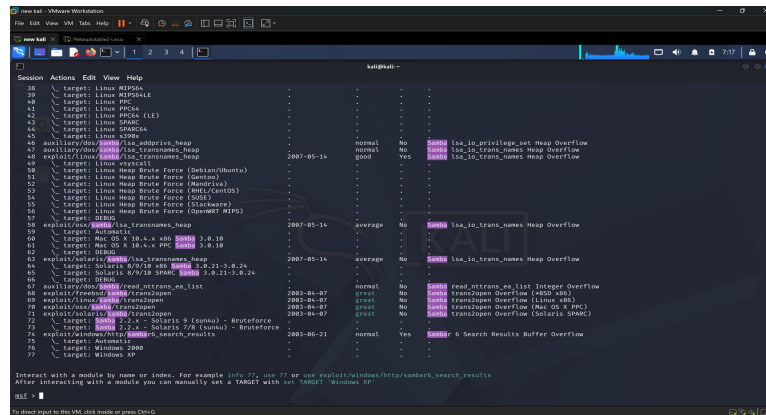


Figure 10: Additional Samba exploits including usermap_script

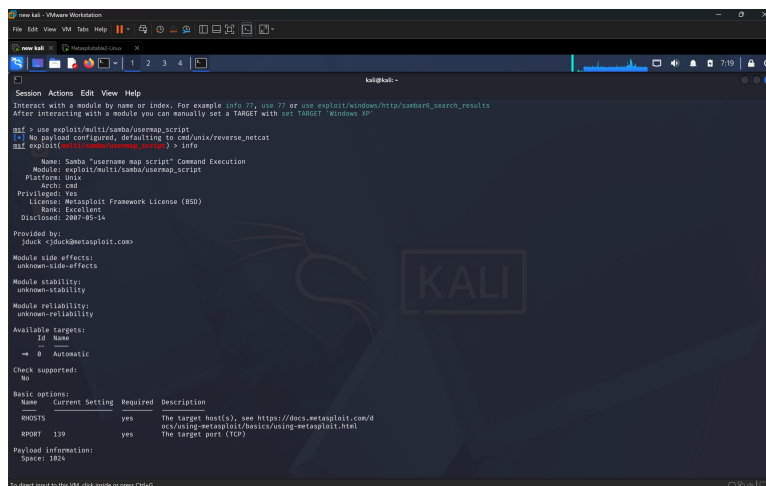


Figure 11: Detailed information about Samba usermap_script vulnerability (CVE-2007-2447)

The Samba username map script vulnerability (CVE-2007-2447) allows remote code execution by exploiting improper input validation. Attackers can inject shell commands in the username field, which execute with root privileges without requiring authentication.

5.3 Vulnerability #3: Unencrypted Telnet Service

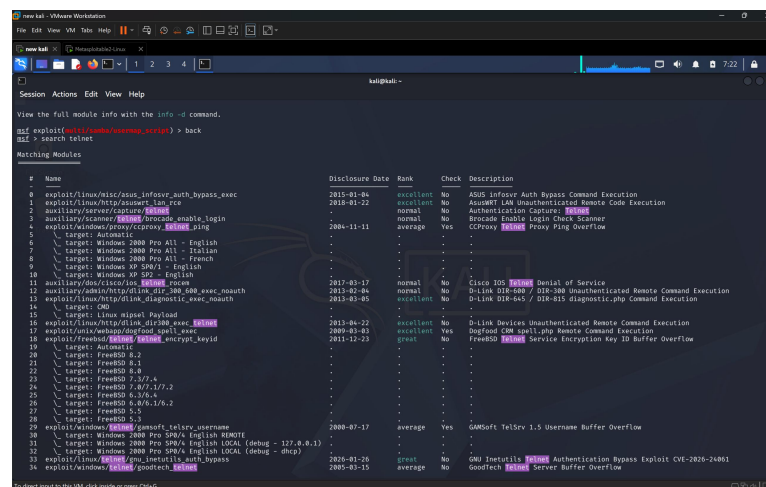


Figure 12: Metasploit search identifying telnet-related vulnerabilities

Telnet transmits all data including credentials in plaintext. Network attackers can use packet capture tools to intercept authentication credentials and session content. The protocol provides no encryption or server authentication, making it fundamentally insecure.

6. Risk Analysis and Mitigation Strategies

6.1 Risk Assessment Matrix

Vulnerability	Severity	Likelihood	Overall Risk
VSFTPD 2.3.4 Backdoor	CRITICAL	High	CRITICAL
Samba Usermap Script	CRITICAL	High	CRITICAL
Unencrypted Telnet	HIGH	Medium	HIGH

6.2 Mitigation Recommendations

- VSFTPD 2.3.4 Backdoor Mitigation:
 - Remove vsftpd 2.3.4 completely and install the latest stable version (3.0.5+) from official repositories. Verify package integrity using GPG signatures. Consider replacing FTP with more secure protocols (SFTP, SCP, or FTPS).
- Samba Usermap Script Mitigation:
 - Update Samba to version 3.0.26 or later. Remove or comment out the 'username map script' directive in smb.conf. Disable SMB v1 protocol and enable SMB signing. Implement IP-based access restrictions.
- Unencrypted Telnet Mitigation:
 - Disable Telnet service immediately and migrate to SSH. Remove the Telnet server package to prevent re-enablement. Configure SSH hardening (disable root login, use key-based authentication, implement fail2ban).
- System-Wide Security Improvements:
 - Establish regular patch management, implement host-based firewall, disable unnecessary services, enable comprehensive logging, and deploy intrusion detection systems.

7. Conclusion

7.1 Assessment Summary

This vulnerability assessment identified significant security weaknesses in the Metasploitable 2 laboratory system. Through systematic reconnaissance, scanning, and analysis, three major vulnerabilities were discovered: two critical remote code execution vulnerabilities (VSFTPD backdoor and Samba usermap script) and one high-severity information disclosure issue (unencrypted Telnet).

The assessment revealed 23 open network ports and services, indicating an excessive attack surface. Each identified vulnerability is well-documented and easily exploitable using publicly available tools, making system compromise highly likely if exposed to untrusted networks.

7.2 Key Findings

The assessment highlighted several critical security principles:

- Software patching is critical - all three vulnerabilities have been resolved in updated versions.
- Attack surface minimization matters - numerous unnecessary services expand potential attack vectors.
- Legacy protocols are dangerous - outdated protocols with inherent security flaws persist long after secure alternatives exist.
- Defense in depth is essential - multiple security layers provide better protection than single measures.
- Supply chain security cannot be ignored - even trusted software sources can be compromised.

7.3 Ethical Considerations

This assessment was conducted entirely within an authorized, isolated laboratory environment. This demonstrates proper security testing practices: only test systems you own or have explicit permission to assess, use isolated environments to prevent damage to production systems, focus on defensive security and understanding vulnerabilities rather than exploitation, and document findings professionally.

7.4 Final Remarks

The vulnerabilities identified represent real-world security challenges affecting production systems worldwide. Understanding these issues in a controlled environment provides valuable insight into system compromise and prevention.

The practical skills developed—network scanning, service enumeration, vulnerability identification, risk analysis, and mitigation planning—form the foundation of professional security work. This assessment demonstrates that with proper methodology and ethical guidelines, security testing strengthens systems rather than breaking them.